4. Check whether any of those permissions permits the requested action.

If the requested action is among the permissions granted by one or more of the user's roles, the request is allowed. Otherwise, it's denied.

As mentioned earlier, RBAC systems often include role hierarchies, where one role inherits the permissions of another. In these cases, the evaluation logic must resolve inherited roles and combine all relevant permissions before making a decision.

RBAC systems may also enforce separation of duty (SoD) constraints, which prevent users from holding conflicting roles. For instance, we don't want one person to have both the `payment-initiator` and the `payment-approver` roles. These constraints help limit the risk of fraud or abuse, especially in regulated or high-stakes environments.

Table 5.3 shows how ACME Corp makes authorization decisions using the roles and permissions defined in figure 5.2. Each decision is based not on individual user-to-resource mappings, but on whether the user's assigned role(s)—and any inherited roles—contain the required permission.